Table of Contents

Cisco Secure Workload — NIST Cybersecurity Framework 2.0

Reference Design | Govern, Identify, Protect, Detect, Respond, Recover

Version: 1.0 (draft — pending SME review) | **Standard:** NIST Cybersecurity Framework 2.0 (February 2024) | **Audience:** Security teams using CSF 2.0 as their organising framework or as a top-level scorecard | **Environment:** Hybrid (on-prem + cloud + containers)

Reader's Guide

Who this is for. Organisations that have adopted the NIST Cybersecurity Framework 2.0 (released February 2024) as their top-level cyber programme reference, or that are reporting CSF posture to their board, regulator, or insurer. CSF 2.0 is not a control catalogue — it's an outcomes framework that **wraps** control catalogues like NIST 800-53, ISO 27001, CIS Controls, and others through Informative References. The right way to read this reference design is as the "where does CSW evidence land in the CSF narrative" view.

What changed in CSF 2.0. The headline change from CSF 1.1 is the addition of a sixth Function — **Govern (GV)** — that sits above Identify, Protect, Detect, Respond, Recover. Govern formalises expectations around organisational context, risk strategy, roles and responsibilities, policy, oversight, and cybersecurity supply chain risk management. CSF 2.0 also reorganises and refines several Categories and Subcategories within the existing five Functions.

Questions this reference design helps you answer:

- *GV.OV (Oversight) and GV.SC (Supply Chain): can I produce a recurring evidence pack the management body uses to discharge its governance obligation, with technical detail rather than green-yellow-red dashboards alone?*
- *ID.AM (Asset Management): can I produce a current inventory of CSW-covered workloads, the software running on them, the data they process, and the systems they depend on, refreshed continuously and reconciled with the enterprise source of truth?*
- *PR.IR (Infrastructure Resilience) and PR.PS (Platform Security): can I demonstrate that network architecture is least-privileged at the workload level (PR.IR-02), that platforms are configured to a baseline (PR.PS-01), and that software is maintained (PR.PS-02)?*
- *DE.CM (Continuous Monitoring): can I prove that workloads are continuously monitored (DE.CM-09), that the network is monitored (DE.CM-01), and that adverse events are detected with sufficient detail to investigate (DE.AE)?*

- *RS.MI (Incident Mitigation) and RS.AN (Incident Analysis): when an event is declared, can I assemble the forensic context to support analysis and apply containment without the playbook stalling on data-gathering?*
- *RC.RP (Incident Recovery Plan Execution): after recovery, can I show diff between pre-incident and post-incident segmentation state, demonstrating the control surface actually changed?*

What you'll need. Your current CSF Profile (target Tier and prioritised Subcategories), your asset inventory source of truth, your incident response process, and the SIEM destination for log forwarding. CSW augments these; it does not author the Profile.

Where to start. Section 2 if you're scoping CSW relative to your CSF Profile; sections 3–4 for the scope tree and the policy set that make the Protect outcomes demonstrable; section 5 if Govern is the new gap (most common post-2.0 question); sections 6–10 walk Identify through Recover mapped to CSW.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	**Live** network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement **operates**

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: Compliance evidence playbook (full step-by-step) · About CSW (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Govern (GV.OV/GV.SC) + ID.AM, PR.IR, DE.CM, RS.AN subcategories
- Outcomes wrapper aligned to 800-53 evidence underneath
- Continuous vs. periodic evidence for CSF maturity conversations

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

---

1. Overview

CSF 2.0 organises cybersecurity outcomes across six Functions, 22 Categories, and 106 Subcategories:

Function	Code	Purpose	CSW relevance
Govern	GV	Establish, communicate, monitor cybersecurity strategy	Supporting (evidence to management body)
Identify	ID	Asset, risk, supply chain understanding	**Direct** (asset management, risk assessment evidence)
Protect	PR	Safeguards limiting/containing impact	**Direct** (infrastructure resilience, platform security)

Function	Code	Purpose	CSW relevance
Detect	DE	Find and analyse adverse events	**Direct** (continuous monitoring, adverse event analysis)
Respond	RS	Take action to contain	**Direct** (incident analysis, mitigation evidence)
Recover	RC	Restore assets and operations	Supporting (post-recovery diff evidence)

Where CSW fits — the short version. CSW is the workload-tier evidence engine for the technical Subcategories under Identify (asset management, risk assessment of workloads), Protect (platform security, infrastructure resilience), Detect (continuous monitoring, adverse event analysis), and Respond (analysis, mitigation). Govern and Recover are organisational/process Functions where CSW supplies inputs (evidence packs, post-incident diffs) but is not the primary control.

CSF 2.0 vocabulary recap. Each Subcategory is identified as `FUNCTION.CATEGORY-NN` (e.g. `PR.IR-02`). Some Subcategories carry implementation examples; the framework remains *outcomes-focused* and explicitly defers to your Profile to scope what's in/out and what depth is expected.

---

2. Profile and Tier Calibration

CSF 2.0 expects organisations to develop a Current Profile, a Target Profile, and to track progress between them. CSW labelling should reflect the Profile so evidence aggregates per Subcategory.

CSW Implementation:

```
Step 1: Apply CSF context labels to every CSW-managed workload
  CSW UI → Inventory → Bulk Label
  Mandatory labels:
    csf_tier:          partial | risk-informed | repeatable | adaptive
    business_function: [function the workload supports]
    data_class:        public | internal | confidential | regulated
    crit_band:         crown-jewel | high | medium | low
    profile_scope:     in-target | not-in-target

Step 2: Build CSW Scopes per (csf_tier, crit_band)
  CSW UI → Organize → Scopes → New
  → Scopes become the unit of evidence aggregation per Subcategory
```

```
Step 3: Schedule Subcategory-aligned evidence pulls
  → Inventory snapshot per ID.AM cadence
  → Vulnerability list per ID.RA cadence
  → Drift report per PR.PS cadence
  → Detection summary per DE.CM cadence
  → Incident dossier per RS.AN format
```

---

3. Scope Architecture and Labeling

Section 2 sets the Profile labels. This section turns them into the scope tree that the Identify and Protect functions are assessed against. The tree is the direct evidence artifact for **ID.AM-03** — representations of authorized network communication and internal and external data flows — which is the Subcategory most organisations satisfy with a stale Visio diagram.

3.1 Suggested Scope Architecture

```
Root Scope
└── Enterprise
    ├── Crown-Jewel-Systems                (crit_band = crown-jewel)
    │   ├── Business-Critical-Applications
    │   └── Critical-Data-Stores
    ├── Business-Applications
    │   ├── External-Facing
    │   └── Internal-Facing
    ├── Shared-Infrastructure
    │   ├── Identity-Services
    │   └── Logging-and-Monitoring
    ├── Privileged-Access-Paths
    └── Third-Party-Connectivity
```

Mirror `crit_band` onto the top-level branches rather than inventing a second criticality vocabulary. The Profile in section 2 is what the Govern function reports against, so a scope tree that disagrees with it produces two different answers to the same risk question.

3.2 Inventory Filters

```
Filter: Crown-Jewel-Systems
  - Tag: crit_band = crown-jewel
  - Tag: business_function matches the Target Profile priority list

Filter: Critical-Data-Stores
  - Tag: data_class = regulated | confidential
  - Listening port: 1433, 1521, 3306, 5432, 27017

Filter: Third-Party-Connectivity
  - Destination outside on-prem and cloud allow-lists
  - Tag: managed_by = vendor | service-provider
```

```
Filter: Profile-Gap-Candidates
  - Tag: profile_scope = in-target
  - No enforcing policy workspace covering the workload
```

`Profile-Gap-Candidates` is the filter that makes CSF progress tracking mechanical: it returns exactly the workloads the Target Profile claims will be protected but which no enforced policy currently covers.

3.3 Labeling Strategy

The five keys from section 2 carry the Profile; the rest below make the Protect and Detect Subcategories queryable.

Label key	Example values	Why it matters for CSF 2.0
`csf_tier`	partial, risk-informed, repeatable, adaptive	*(section 2)* Governance tier the workload's evidence supports
`business_function`		*(section 2)* Ties technical evidence to the Govern function's business context
`data_class`	public, internal, confidential, regulated	*(section 2)* PR.DS scope membership and plaintext-flow findings
`crit_band`	crown-jewel, high, medium, low	*(section 2)* Drives scope placement and enforcement sequencing
`profile_scope`	in-target, not-in-target	*(section 2)* Separates Current Profile reality from Target Profile intent
`dependency_tier`	edge, app, data, shared	Makes the ID.AM-03 flow representation readable per tier
`recovery_tier`	rto-critical, rto-standard	RC.RP sequencing — which scopes come back first
`compliance`	nist-csf-2	Filters CSW evidence to the CSF assessment boundary

4. Policy Design — PR.IR and PR.AA Enforcement

CSF 2.0 is outcome-based rather than prescriptive, so the policy set is not a checklist item — it is the mechanism by which several Protect Subcategories become demonstrable. Write it so each rule maps to a Subcategory an assessor can name.

4.1 Subcategory-Aligned Policy Framework

Absolute policies:

```
DENY  Any                          → Crown-Jewel-Systems      (default
deny inbound — PR.IR-01)
DENY  Crown-Jewel-Systems          → Internet                 (no
direct egress from crown jewels)
DENY  Third-Party-Connectivity     → Crown-Jewel-Systems      (vendor
paths terminate short of crown jewels)
DENY  Business-Applications        → Crown-Jewel-Systems
(promotion only via documented interfaces)
```

Allowlist policies (least privilege — PR.AA-05):

```
ALLOW External-Facing              → Internal-Facing          tcp/443
ALLOW Internal-Facing              → Critical-Data-Stores     tcp/<db-
port-tls>
ALLOW Crown-Jewel-Systems          → Identity-Services        tcp/636,
tcp/88
ALLOW Privileged-Access-Paths      → Crown-Jewel-Systems      tcp/22,
tcp/3389
ALLOW Enterprise                   → Logging-and-Monitoring   tcp/443,
udp/514
```

Catch-all:

```
LOG   Any                          → Crown-Jewel-Systems
(unmatched inbound — DE.CM-01)
LOG   Crown-Jewel-Systems          → Any
(unmatched outbound — DE.CM-01)
LOG   Enterprise                   → Any
(plaintext: tcp/80, tcp/21, tcp/23, tcp/389, udp/161)
```

4.2 Policy Workspace Lifecycle

Phase	Mode	Duration	Purpose
1	Simulation	2 weeks	Validate the candidate policy
2	Enforcement (high-confidence rules only)	1 week	Enforce obvious deny rules
3	Full Enforcement	Ongoing	Workload allowlist

Phase	Mode	Duration	Purpose
			enforced; monthly exception review

4.3 Policy State as Profile Progress

The Current-to-Target Profile delta is usually tracked in a spreadsheet that ages immediately. Policy state is a better source because it cannot drift from reality:

Policy state for a scope	Current Profile reality	Subcategory evidence
No workspace	ID.AM-03 partially met at best	ADM baseline only
Simulation	Protect outcomes designed, not achieved	Policy export + simulation report
Enforced, deny-by-default inbound	PR.IR-01 and PR.AA-05 demonstrable	Policy export + Denied Connections
Enforced with pre-staged containment rules	RS.MI-01 / RS.MI-02 demonstrable	Containment policy + exercise record

Pre-staging containment rules in a disabled workspace is worth calling out to the assessor: it converts RS.MI from a written procedure into a tested capability with a measurable activation time.

---

5. Govern (GV) — Organisational Context, Strategy, Oversight

GV is the new Function in CSF 2.0. CSW does not establish strategy or assign roles. It contributes by supplying the *technical evidence pack* the management body needs to discharge GV.OV (Oversight) and GV.SC (Supply Chain) responsibilities credibly.

Subcategories where CSW supplies inputs:

Subcategory	Topic	CSW input
GV.OV-01	Cybersecurity strategy outcomes are reviewed	Quarterly evidence pack feeding the review
GV.OV-02	Cybersecurity risk management strategy adjusted	Trend reports (incident counts, MTTD/MTTR, vuln backlog)
GV.OV-03	Cybersecurity strategy and capabilities evaluated	Posture summary across ID/PR/DE/RS
GV.SC-04	Suppliers known and prioritised	Vendor-egress inventory per scope
GV.SC-07	Risks of suppliers	Vendor-egress drift

Subcategory	Topic	CSW input
	monitored	report
GV.SC-09	Supply chain security practices integrated	Egress allowlist + reconciliation against contract register
GV.SC-10	Cybersecurity supply chain risk management plans address end-of-life	Software inventory with vendor-EOL flags

CSW Implementation:

```
Step 1: Standing quarterly evidence pack to management body
  Sections (each ~1 page):
    1. Workload inventory drift summary (ID.AM)
    2. Vulnerability backlog by criticality (ID.RA / PR.PS)
    3. Segmentation policy diff (PR.IR)
    4. Detection summary + MTTD/MTTR trend (DE.CM / RS.AN)
    5. Incident summary with severity distribution (RS / RC)
    6. Vendor-egress drift summary (GV.SC)
    7. Open audit/regulatory findings + remediation (GV.OV)

Step 2: Schedule generation
  → CSW reports (Inventory, Vulnerability, Policy Diff, Alert
    Summary) all available via API for automated aggregation
  → Recommended: stand up a small report-generation script that
    pulls each section monthly and rolls up quarterly
```

Evidence: standing quarterly evidence pack with auditable generation date and management-body sign-off.

---

6. Identify (ID) — Asset Management, Risk Assessment

CSF 2.0 emphasises Identify as the precondition for everything downstream. You can't protect what you can't see; you can't prioritise risk you can't measure.

Subcategories where CSW is the primary technical control:

ID.AM — Asset Management

Subcategory	Topic	CSW capability
ID.AM-01	Inventories of hardware are maintained	Continuous workload inventory + cloud asset metadata
ID.AM-02	Inventories of software, services, and systems are maintained	Per-workload package + service inventory

Subcategory	Topic	CSW capability
ID.AM-03	Representations of organisation's authorised network communication and internal/external network data flows are maintained	ADM dependency graph; observed flow inventory
ID.AM-04	Inventories of services provided by suppliers are maintained	Vendor-egress observation + reconciliation
ID.AM-05	Assets are prioritised based on classification, criticality, resources, and impact	`crit_band` labels drive scope-based prioritisation
ID.AM-07	Inventories of data and corresponding metadata for designated data types are maintained	Workload labels (`data_class`) anchor data-tier inventory
ID.AM-08	Systems, hardware, software, services, and data are managed throughout their lifecycle	Vendor-EOL flag in software inventory

ID.RA — Risk Assessment

Subcategory	Topic	CSW capability
ID.RA-01	Vulnerabilities in assets are identified, validated, recorded	Continuous CVE inventory per workload
ID.RA-02	Cyber threat intelligence is received	CSW threat-intel feeds enrich CVE prioritisation
ID.RA-03	Internal and external threats are identified and recorded	Behavioural detection rule catalogue
ID.RA-05	Threats, vulnerabilities, likelihoods, and impacts are used to understand inherent risk and inform risk response prioritisation	Reachability-aware CVE prioritisation
ID.RA-06	Risk responses are chosen, prioritised,	CVE backlog + remediation tracking +

Subcategory	Topic	CSW capability
	planned, tracked, and communicated	compensating-control register
ID.RA-07	Changes and exceptions are managed, assessed for risk impact, recorded, and tracked	Configuration drift report + change-ticket attribution

CSW Implementation:

```
Step 1: Achieve sensor + cloud-connector coverage (ID.AM-01/02)
Step 2: Run ADM per crit_band scope (ID.AM-03)
Step 3: Schedule continuous vulnerability inventory (ID.RA-01)
Step 4: Wire reachability + EPSS into CVE triage (ID.RA-05)
Step 5: Schedule weekly drift report tied to change tickets (ID.RA-07)
```

---

7. Protect (PR) — Safeguards

CSF 2.0 reorganised Protect substantially in 2024. The most CSW- relevant Categories are PR.IR (Infrastructure Resilience) and PR.PS (Platform Security).

PR.IR — Infrastructure Resilience (Network Protection)

Subcategory	Topic	CSW capability
PR.IR-01	Networks and environments are protected from unauthorised logical access and usage	Workload-level deny-by-default segmentation enforcement
PR.IR-02	The organisation's technology assets are protected from environmental threats	(CSW does not address physical/environmental — out of scope)
PR.IR-03	Mechanisms are implemented to achieve resilience requirements in normal and adverse situations	Quarantine policy for incident response; segmentation evolves under change control
PR.IR-04	Adequate resource capacity to ensure availability is maintained	(CSW supports detection of resource-exhaustion patterns; primary control is capacity planning)

PR.PS — Platform Security

Subcategory	Topic	CSW capability
PR.PS-01	Configuration management practices are established and applied	Daily baseline + drift detection
PR.PS-02	Software is maintained, replaced, and removed commensurate with risk	Per-workload software inventory + vendor-EOL tagging
PR.PS-03	Hardware is maintained, replaced, and removed commensurate with risk	Inventory drift + asset lifecycle tagging
PR.PS-04	Log records are generated and made available for continuous monitoring	Per-flow + per-process telemetry to SIEM
PR.PS-05	Installation and execution of unauthorised software are prevented	Behavioural rules + (IG3) allow-list block
PR.PS-06	Secure software development practices are integrated, and their performance is monitored	CVE inventory feeds the SDLC; reachability for triage

PR.AA — Identity Management, Authentication, Access Control

CSW is supporting here; identity is upstream. CSW enforces workload-side outcomes of upstream identity decisions.

Subcategory	Topic	CSW capability
PR.AA-01	Identities and credentials for authorised users, services, and hardware are managed	Workload labels carry identity context for policy decisions
PR.AA-05	Access permissions, entitlements, and authorisations are defined in a policy, managed, enforced, and reviewed	Workload-tier policy enforcement + quarterly access review

PR.DS — Data Security

Subcategory	Topic	CSW capability
PR.DS-01	The confidentiality, integrity, and availability of data-at-rest are protected	(Out of scope — encryption at rest is upstream)
PR.DS-02	The confidentiality, integrity, and availability of data-in-transit are protected	Plaintext-protocol DENY enforcement

CSW Implementation:

```
Step 1: Per-scope segmentation policy (PR.IR-01)
  → Build policy workspace; default deny; ADM-derived allow-list

Step 2: Daily baseline + drift detection (PR.PS-01)
  → Snapshot OS + packages + listening ports + processes
  → Daily diff with disposition column

Step 3: Software lifecycle (PR.PS-02)
  → Tag workloads running EOL software; route to platform team

Step 4: SIEM forwarding (PR.PS-04)
  → Per-flow + per-process events forwarded continuously

Step 5: Behavioural prevention (PR.PS-05)
  → Forensics rule catalogue; alert in IG2; block in IG3 patterns

Step 6: Plaintext DENY (PR.DS-02)
  → CSW policy: deny HTTP/FTP/Telnet/LDAP/SMTP plaintext flows
```

---

8. Detect (DE) — Continuous Monitoring, Adverse Event Analysis

The densest CSW alignment in CSF.

DE.CM — Continuous Monitoring

Subcategory	Topic	CSW capability
DE.CM-01	Networks and network services are monitored to find potentially adverse events	CSW flow telemetry + behavioural rules + SIEM forwarding
DE.CM-02	The physical environment is monitored to find	(Out of scope — physical)

Subcategory	Topic	CSW capability
	potentially adverse events	
DE.CM-03	Personnel activity and technology usage are monitored to find potentially adverse events	Process telemetry + identity-aware policy
DE.CM-06	External service provider activities and services are monitored to find potentially adverse events	Vendor-egress observation + drift alerting
DE.CM-09	Computing hardware and software, runtime environments, and their data are monitored to find potentially adverse events	Per-workload process + package + flow telemetry

DE.AE — Adverse Event Analysis

Subcategory	Topic	CSW capability
DE.AE-02	Potentially adverse events are analysed to better understand associated activities	Forensic flow + process timeline reconstruction
DE.AE-03	Information is correlated from multiple sources	CSW telemetry forwarded to SIEM for correlation
DE.AE-04	The estimated impact and scope of adverse events is understood	Reachability + crit_band labels inform impact estimate
DE.AE-06	Information on adverse events is provided to authorised staff and tools	SIEM forwarding + alert routing per scope
DE.AE-07	Cyber threat intelligence and other contextual information are integrated into the analysis	Threat-intel-enriched detections
DE.AE-08	Incidents are declared when adverse events meet the defined	Severity-based alert routing → IR ticket creation

Subcategory	Topic	CSW capability
	incident criteria	

CSW Implementation:

```
Step 1: Behavioural rules across crit_band scopes (DE.CM-01/03/09)
Step 2: Conversation-graph anomaly detection (DE.CM-01)
Step 3: SIEM forwarding for correlation (DE.AE-03/06)
Step 4: Threat-intel enrichment in CVE + behavioural pipeline
(DE.AE-07)
Step 5: Severity-based incident-declaration thresholds (DE.AE-08)
```

---

9. Respond (RS) — Analysis, Mitigation, Reporting

RS.MA — Incident Management

Subcategory	Topic	CSW capability
RS.MA-01	The incident response plan is executed in coordination with relevant third parties	Six-artefact dossier ready for handoff
RS.MA-02	Incident reports are triaged and validated	Forensic context per dossier
RS.MA-03	Incidents are categorised and prioritised	crit_band + reachability inform priority
RS.MA-04	Incidents are escalated or elevated as needed	Severity routing per scope
RS.MA-05	The criteria for initiating incident recovery are applied	Containment evidence informs recovery readiness

RS.AN — Incident Analysis

Subcategory	Topic	CSW capability
RS.AN-03	Analysis is performed to establish what has taken place during an incident and the root cause	Process + flow timeline reconstruction
RS.AN-06	Actions performed during an investigation are recorded and the records' integrity and provenance are preserved	CSW retains all queries and exports; SIEM hashing for chain-of-custody
RS.AN-07	Incident data and	Six-artefact dossier with

Subcategory	Topic	CSW capability
	metadata are collected and their integrity and provenance are preserved	timestamped exports
RS.AN-08	An incident's magnitude is estimated and validated	Reachability + scope membership inform magnitude

RS.MI — Incident Mitigation

Subcategory	Topic	CSW capability
RS.MI-01	Incidents are contained	Quarantine policy applied per workload
RS.MI-02	Incidents are eradicated	Compensating-control register; sustained policy enforcement

CSW Implementation:

```
Step 1: Standardise the six-artefact incident dossier template
Step 2: Pre-build quarantine policy templates per scope
Step 3: Train SOC analysts on CSW historical query workflow
Step 4: Wire CSW alerts into the IR ticketing system
```

---

10. Recover (RC) — Recovery Plan Execution, Communications

CSW is supporting in Recover. The primary controls are backups, communications, and recovery-plan execution.

Subcategory	Topic	CSW capability
RC.RP-01	The recovery portion of the incident response plan is executed once initiated from the incident response process	Pre-incident segmentation export available for re-application
RC.RP-02	Recovery actions are selected, scoped, prioritised, and performed	(Out of scope — recovery action selection is upstream)
RC.RP-03	The integrity of backups and other restoration assets is verified before using them for	(Out of scope — backup integrity is upstream)

Subcategory	Topic	CSW capability
	restoration	
RC.RP-04	Critical mission functions and cybersecurity risk management are considered to establish post-incident operational norms	Post-recovery segmentation diff = evidence of new normal
RC.RP-05	The integrity of restored assets is verified, systems and services are restored, and normal operating status is confirmed	CSW re-baseline after recovery shows package + listening-port state
RC.RP-06	The end of incident recovery is declared based on criteria, and incident-related documentation is completed	Final dossier inclusion of post-recovery diff

11. Mapping Table — CSF 2.0 Subcategory → CSW Capability

(Consolidated from sections 5–10)

Subcategory	Topic	CSW capability
GV.OV-01/02/03	Oversight	Quarterly evidence pack to management body
GV.SC-04/07/09/10	Supply chain	Vendor-egress observation + reconciliation
ID.AM-01 to 08	Asset management	Continuous inventory + ADM + EOL tagging
ID.RA-01/05/06/07	Risk assessment	CVE inventory + reachability + drift
PR.AA-01/05	Identity & access	Workload-side enforcement
PR.DS-02	Data-in-transit	Plaintext DENY enforcement
PR.IR-01/03	Infrastructure resilience	Segmentation enforcement; quarantine policy

Subcategory	Topic	CSW capability
PR.PS-01 to 06	Platform security	Baseline + drift + EOL + SIEM + behavioural rules
DE.CM-01/03/06/09	Continuous monitoring	Workload telemetry + behavioural rules
DE.AE-02/03/04/06/07/08	Adverse event analysis	Forensic timeline + SIEM correlation + threat intel
RS.MA-01 to 05	Incident management	Six-artefact dossier + severity routing
RS.AN-03/06/07/08	Incident analysis	Process + flow timeline + magnitude estimate
RS.MI-01/02	Incident mitigation	Quarantine policy + compensating controls
RC.RP-04/05/06	Recovery actions (evidence)	Post-recovery segmentation diff + re-baseline

12. Auditor / Assessor Response Guide

When a CSF assessment asks for evidence:

Assessor asks	You provide
"Show your CSF Profile and current Tier evidence"	Quarterly evidence pack + Profile-aligned scope inventory
"Demonstrate ID.AM-01/02/03 asset & flow inventory"	Inventory CSV + ADM dependency graph per crit_band scope
"Provide ID.RA-01/05/06 vulnerability evidence"	CVE list per workload + reachability scoring + remediation tracking
"Show PR.IR-01 network protection"	Workspace export + simulation → enforcement log
"Demonstrate PR.PS-01 configuration management"	Daily baseline + drift report tied to change ticket
"Provide DE.CM-09 continuous monitoring evidence"	Per-workload process + package + flow telemetry retention
"Show RS.AN-03 incident analysis"	Six-artefact dossier per declared incident
"Provide GV.SC-07 supplier monitoring evidence"	Vendor-egress drift report + reconciliation

13. Related Frameworks

CSF 2.0 wraps and references many control catalogues. Key cross-references in this repository:

- **NIST SP 800-53 Rev 5** — the most common Informative Reference source under CSF 2.0 Subcategories. Many `PR.PS`, `PR.IR`, `DE.CM` Subcategories cite specific 800-53 controls. See 800-53 reference design.
- **NIST SP 800-207 (Zero Trust Architecture)** — the seven ZTA tenets implement many `PR.AA`, `PR.IR`, `DE.CM` outcomes. See 800-207 reference design.
- **CIS Critical Security Controls v8.1** — common Informative Reference; CIS Safeguard 4.1 ↔ PR.PS-01, 13.x ↔ DE.CM-01, etc. See CIS reference design.
- **CMMC 2.0** — Level 2 ≈ NIST 800-171 ≈ subset of 800-53, which is in turn cited under CSF Subcategories. See CMMC reference design.
- **ISO/IEC 27001:2022** — Annex A controls cited as Informative References under many CSF Subcategories. See ISO 27001 reference design.
- **CISA Zero Trust Maturity Model** — sector-government overlay that aligns with CSF 2.0 outcomes. See CISA ZTMM reference design.
- **UK NCSC CAF v3.2** — CSF outcomes are the reuse language for CAF A–D (see CAF crosswalk).

---

14. Disclaimer

This reference design is **draft v1** describing how Cisco Secure Workload capabilities can support a NIST Cybersecurity Framework 2.0 programme. It is **not** legal or compliance advice and does not constitute a finding of compliance.

Specifically:

- NIST publishes the authoritative CSF 2.0 text and Subcategory list at https://www.nist.gov/cyberframework. Always validate against the **current effective version** of CSF, including any released Quick-Start Guides, Profiles, and Implementation Examples.
- CSF 2.0 is an outcomes framework and does not prescribe specific controls. Mapping a CSW capability to a Subcategory does not by itself satisfy the Subcategory — the organisation's Profile, Tier, and accompanying control set determine the depth of work expected.
- CSW does not address physical/environmental Subcategories (`PR.IR-02`, `DE.CM-02`), backup/recovery Subcategories (`RC.RP-02/03`), or training/HR-style Subcategories. Reference the appropriate parts of your programme for those.

This document should receive subject-matter-expert review for both CSF 2.0 currency and current Cisco product capability before being relied upon in a formal compliance engagement.